

Password Policy

Document Control

Field	Value
Policy ID	POL-SEC-003
Version	1.0
Effective Date	2026-08-19
Review Date	2027-08-19
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Management / Board Risk Committee
Classification	Internal

1. Purpose

This policy establishes requirements for creating, managing, storing, and protecting passwords and other authentication credentials used to access SecureBank Financial Services systems. Its purpose is to reduce the risk of unauthorized access to customer financial data and core banking infrastructure, ensure the confidentiality and integrity of company and customer information, and satisfy SecureBank's obligations under **PCI-DSS**, **SOX**, and **FFIEC** guidance, as well as current authentication best practices published in **NIST SP 800-63B**.

2. Scope

2.1 Applicability

This policy applies to:

- ☒ All employees
- ☒ Contractors and consultants
- ☒ Third-party vendors with access to company systems
- ☒ Remote workers

2.2 Systems/Assets Covered

This policy covers all systems requiring authentication at SecureBank Financial Services, including:

- Core banking system (critical)
- Customer-facing online/mobile banking portal
- Employee workstations and laptops
- Administrative and privileged access systems (servers, network devices, databases, cloud consoles)
- Software development and testing environments

2.3 Exclusions

This policy does not apply to customer-managed authentication for personal banking accounts, which is governed by the separate Customer Authentication Standard. Service accounts and non-interactive system accounts are governed by the Privileged Access Management (PAM) provisions in Section 3.5 and the associated Technical Standards document.

3. Policy Statements

3.1 Password Requirements

Password requirements are risk-based and vary by system criticality and authentication context, consistent with NIST SP 800-63B and applicable regulatory requirements.

Requirements:

- Minimum password length of **15 characters** for accounts that rely on a password as the sole authentication factor
- Minimum password length of **12 characters** for accounts protected by an approved second authentication factor (MFA)
- Maximum password length must be at least **64 characters**, and systems must accept spaces and all printable ASCII/Unicode characters to support passphrases
- Arbitrary composition rules (mandatory mixes of uppercase, lowercase, numbers, and symbols) must not be enforced; length and uniqueness are the primary controls
- All new and changed passwords must be checked against a blocklist of known-breached, commonly used, and context-specific weak passwords (e.g., "SecureBank," "P@ssw0rd," seasonal patterns) and rejected if matched

- Passwords must not be reused across SecureBank systems or reused from any personal account
- Systems must allow users to view the password as it is typed rather than displaying only masked characters, and must support secure paste functionality from password managers

3.2 Password Management

Password change, reset, and session-handling procedures are designed to limit exposure from compromised credentials while avoiding practices known to weaken security, such as arbitrary forced rotation.

Requirements:

- Passwords must be changed immediately upon evidence or suspicion of compromise, and must not otherwise be subject to mandatory periodic rotation, in line with current NIST guidance — **except** where a specific PCI-DSS, SOX-related control, or examiner requirement mandates periodic rotation for a given system, in which case the stricter regulatory requirement governs and is documented in the Technical Standards
- Default or vendor-supplied passwords must be changed before any system is placed into production
- Password reset requests must include identity verification through the IT Service Desk or an approved self-service tool using a second authentication factor
- Accounts must lock after **5 consecutive failed login attempts**; standard user accounts unlock automatically after 30 minutes or via verified Service Desk request, while lockouts on core banking and administrative systems require manual unlock by IT Security
- Interactive sessions on the core banking system and administrative systems must time out after **15 minutes** of inactivity; general workstation and customer portal sessions must time out after **30 minutes** of inactivity
- Employees must not store passwords in plain text, in browsers without an approved enterprise password management add-on, or in unencrypted documents or messages

3.3 Multi-Factor Authentication (MFA)

MFA is required wherever supported and is mandatory for all access to systems processing cardholder or customer financial data, consistent with PCI-DSS Requirement 8 and FFIEC guidance.

Requirements:

- MFA is mandatory for all remote access to the corporate network (VPN), all administrative/privileged access, all access to the core banking system, and all access to systems in the PCI-DSS cardholder data environment
- MFA is mandatory for customer access to the online/mobile banking portal
- Approved MFA methods, in order of preference, are: phishing-resistant methods (FIDO2/WebAuthn security keys, device-bound passkeys), authenticator app push notifications or time-based one-time passcodes (TOTP), and SMS/voice one-time passcodes (permitted only where stronger methods are not yet supported, and scheduled for phase-out)
- Knowledge-based authentication (e.g., security questions such as "mother's maiden name") must not be used as an MFA factor or as a sole account-recovery mechanism
- Privileged and administrative accounts must use a phishing-resistant MFA method; SMS-based MFA is not permitted for privileged access
- MFA enrollment is mandatory for all employees, contractors, and vendors prior to being granted system access

3.4 Storage

Password storage must protect credentials against disclosure even in the event of a database compromise.

Requirements:

- Passwords must never be stored in plain text, reversibly encrypted, or in any recoverable form
- Passwords must be stored using a modern, salted, computationally expensive hashing algorithm approved in the Technical Standards document (e.g., bcrypt, scrypt, or Argon2)
- Password hashing configuration (salt length, work factor/cost parameters) must be reviewed at least annually and updated as computing power increases
- Employees and contractors must use the company-approved enterprise password manager to generate and store passwords for work-related accounts; use of unapproved consumer password manager tools for company credentials is prohibited
- Credential stores, hashing secrets, and pepper values must be protected using the same or greater controls as the systems in Section 3.5 for privileged accounts

3.5 Privileged Accounts

Privileged and administrative accounts present elevated risk and require enhanced controls beyond standard user accounts.

Requirements:

- All privileged accounts (system administrators, database administrators, network administrators, cloud administrators, core banking system administrators) must be provisioned and managed through the company's Privileged Access Management (PAM) solution
- Standing/persistent privileged access is prohibited where technically feasible; privileged access must be granted just-in-time through the PAM solution with a defined, time-limited session and full session recording
- Privileged account passwords must meet a minimum length of **20 characters**, be unique per system, and be rotated automatically by the PAM solution on a schedule defined in the Technical Standards document
- Privileged accounts must never be shared between individuals; each administrator must have a uniquely attributable account
- All privileged account activity must be logged, and logs must be retained and reviewed in accordance with SOX and FFIEC audit requirements
- Emergency ("break-glass") access to privileged credentials outside the PAM solution is permitted only under the documented emergency access procedure, requires dual approval, and must be followed by mandatory password rotation and incident review within 24 hours

4. Roles and Responsibilities

Role	Responsibilities
Executive Management / Board Risk Committee	Approve this policy, allocate resources for its implementation, and maintain oversight of regulatory compliance (PCI-DSS, SOX, FFIEC)
CISO / IT Security Team	Own the Technical Standards document, configure and enforce authentication controls, manage the PAM solution, monitor for compromised credentials, and lead incident response
Internal Audit	Independently test password and authentication controls for SOX and FFIEC compliance and report findings to the Board Risk Committee
Department Managers	Ensure their teams understand and comply with this policy and support required training

All Employees, Contractors, and Vendors	Create and protect passwords per Section 3, enroll in and use required MFA, use the approved password manager, and report suspected credential compromise immediately
PAM/Privileged Account Holders	Comply with enhanced privileged account requirements in Section 3.5 and use only individually attributable accounts

5. Compliance

5.1 Monitoring

IT Security will continuously monitor authentication systems for failed login patterns, credential-stuffing indicators, impossible-travel logins, and PAM session activity, and will screen for exposure of company credentials in known breach data.

5.2 Reporting

Suspected credential compromise, phishing attempts, or authentication anomalies must be reported immediately to IT Security at security@securebank.com or via the 24/7 IT Service Desk. Reports may be made through the confidential ethics hotline where preferred.

5.3 Auditing

Compliance with this policy will be independently audited at least annually as part of SOX internal controls testing and FFIEC examination readiness, and PCI-DSS-scoped systems will undergo authentication control testing at the frequency required by the current PCI-DSS assessment cycle. Audit findings will be reported to the Board Risk Committee.

6. Enforcement

6.1 Violations

Violations of this policy may result in:

- Verbal warning
- Written warning
- Suspension of system access privileges
- Mandatory retraining on authentication and password security
- Disciplinary action up to and including termination
- Legal or regulatory action where applicable, including reporting obligations triggered under PCI-DSS, SOX, or FFIEC requirements

6.2 Reporting Violations

Report suspected violations to IT Security at security@securebank.com, via the IT Service Desk, or through the confidential ethics hotline.

7. Exceptions

7.1 Exception Process

Exceptions to this policy require:

1. A written request submitted to the CISO
2. A documented business justification
3. A risk assessment conducted by IT Security, including an assessment of impact on PCI-DSS, SOX, or FFIEC compliance
4. Compensating controls where applicable (e.g., additional monitoring, network segmentation)
5. Formal written approval and documentation retained by IT Security and made available to auditors and examiners on request

7.2 Exception Duration

All exceptions must have a defined end date and be reviewed quarterly. Exceptions affecting systems in PCI-DSS scope must be reviewed prior to each PCI-DSS assessment cycle.

8. Definitions

Term	Definition
Multi-Factor Authentication (MFA)	An authentication method requiring two or more independent verification factors
Phishing-Resistant MFA	An MFA method (e.g., FIDO2/WebAuthn, device-bound passkey) designed to resist credential relay and real-time phishing attacks
Privileged Access Management (PAM)	A system used to secure, control, and monitor access to privileged/administrative accounts, typically including credential vaulting and just-in-time access
Blocklist	A list of known-breached, commonly used, or predictable passwords that are rejected during password creation

Hashing	A one-way cryptographic transformation used to store passwords so the original value cannot be recovered
Break-Glass Access	Emergency access to privileged credentials outside normal PAM workflow, used only in defined emergency circumstances
Cardholder Data Environment (CDE)	The systems, people, and processes that store, process, or transmit cardholder data, as scoped under PCI-DSS

9. Related Documents

- Acceptable Use Policy
- Privileged Access Management (PAM) Standard
- Password Policy — Technical Standards (companion document)
- Customer Authentication Standard
- Incident Response Plan
- NIST SP 800-63B: Digital Identity Guidelines
- OWASP Authentication Cheat Sheet
- PCI-DSS v4.0 Requirement 8
- CISA Multi-Factor Authentication Guide

10. Revision History

Version	Date	Author	Description
1.0	2026-08-19	CISO	Initial release, aligned with NIST SP 800-63B, PCI-DSS v4.0 Requirement 8, SOX, and FFIEC guidance

11. Acknowledgment

By accessing SecureBank Financial Services systems, all employees, contractors, and vendors acknowledge they have read, understood, and agree to comply with this Password Policy.

For formal acknowledgment tracking, use the company's policy acknowledgment system.

End of Policy Document